Governing Enterprise AI Traffic at Scale:
Design and Operation of a Policy-Driven, Multi-Vendor LLM Gateway on Envoy

Mithun Sasidharan* Srinivasan Manoharan Rupesh Thakur
Abhinav TK Ashwin Hegde Anand Gautam

PayPal Inc.

arXiv:2610.35509v1 [cs.DC] 26 Oct 2026

Abstract

Large organizations now consume large language models (LLMs) from several vendors at once, and each vendor brings its own API dialect, credential model, streaming protocol, pricing and release cadence. Integrated directly, this heterogeneity yields credential sprawl, format lock-in, unbounded spend and inconsistent governance. We present the design and production operation of the **Cosmos LLM Gateway**, the governed entry point for enterprise LLM traffic at PayPal. The gateway is built on Envoy and splits work by latency profile: I/O-bound control decisions (authentication, credential brokering, policy and budget evaluation) run in an out-of-process external-processing service, while latency-sensitive payload work (wire-format translation, token metering and prompt-cache shaping) runs in-proxy as a Rust WebAssembly filter, so that, by default, streamed response body chunks never wait on an out-of-process call. Models, providers and prices are largely a validated data model rather than code. Governance is declarative policy evaluated by Open Policy Agent and managed through a control plane with role-scoped authoring for platform and business-unit administrators, approval workflows, scheduled activation, limited-access model releases, cohort-based pilots, shadow-mode rollout, configurable usage notifications and versioned policy-bundle distribution. For use cases that require it, a data-loss-prevention layer that combines pattern rules with an internally hosted detection model can block, redact or reversibly pseudonymize detected sensitive content before it reaches a provider. Every spend scope is a *view* over per-model usage counters, so a new budget applies to spend already recorded in its window without data migration, and every governed request is designed to yield one deduplicated usage record in the analytics warehouse. As of September 2026, the gateway serves more than 12,000 developers and hundreds of business use cases, including real-time voice support with more than 2,000 concurrent calls. It handles millions of requests and roughly 200 billion tokens per day across more than 100 models from multiple providers, at 99.999% availability to business. In a benchmark of the core request path against a synthetic upstream, it adds a median of 4 ms and a p99 of 11 ms of overhead at more than 2,200 requests per second on two 4-vCPU instances, with no failed requests across the tested range. We report the architecture, the policy model, an evaluation, and the lessons we would carry to any enterprise standardizing access to multiple AI providers.

Keywords: LLM gateway, AI governance, Envoy, ext_proc, WebAssembly, policy as code, Open Policy Agent, data loss prevention, FinOps, multi-vendor routing, observability.

1 Introduction

Generative AI quickly became a production dependency at PayPal. Engineers use agentic coding tools daily; product teams ship AI-assisted features; and customer-facing systems, including real-time voice support, depend on frontier models being available, governed and affordable. The models these workloads need come from several vendors simultaneously, and the best model for a task can change on a timescale of weeks.

The obvious way to consume these models is for each application to integrate each vendor directly: hold the vendor's key, adopt its request format, handle its streaming semantics, and track its spend locally. That approach works for one team and one model. It does not survive an organization of thousands of engineers and hundreds of production workloads spanning several major providers. Direct integration fails along four compounding axes:

- **Credential sprawl.** Long-lived vendor keys proliferate across applications, with no central place to scope, rotate, attribute or revoke them, and no reliable link from a call to the human who authorized it.
- **Format lock-in.** An application written against one vendor's API cannot adopt another vendor's model without code changes, so model choice, regional placement and failover become engineering projects rather than configuration.
- **Ungoverned spend.** Cost accrues per key and per vendor, with no organization-aware budgets, no early warning and no lever for business-unit leadership.
- **Uneven governance and visibility.** Each integration authenticates, logs, rate-limits and protects data differently; security and finance have no single plane on which to ob-

serve or control AI traffic.

This paper describes how we addressed these failure modes behind a single layer, the Cosmos LLM Gateway. Beyond a unified API and data plane, the system comprises a full governance control plane, a policy-as-code decision engine, a platform-identity service attested by corporate single sign-on (SSO), a durable usage-attribution pipeline and inline data-loss prevention (DLP). This paper documents the system as it now operates.

Contributions. We make the following contributions:

1. A **two-tier Envoy architecture** that runs I/O-bound governance out of process and streaming translation in process, joined by an explicit, contract-tested handoff (section 5).
2. **Models, routing and pricing as validated data**: a registry whose loader enforces a *serviceability invariant*, and a control-plane onboarding lifecycle that takes a model from staged to generally available without a deployment (sections 6 and 10.1).
3. A **canonical intermediate-representation (IR) translation layer** that needs one codec per wire format instead of one converter per format pair, with fast paths that are lossless for client content and gateway-side prompt-cache shaping (section 7).
4. A **layered access and spend policy model**: organization-anchored model restrictions, business-unit controls, and budgets whose scopes are views over per-model counters keyed by immutable model identifiers, which makes them retroactive within a window and migration-free. Policies are evaluated by a pure decision function separated from side effects (section 9).
5. A **governed policy lifecycle** for platform and business-unit administrators: approvals, scheduled activation, pilots with tier ladders, shadow-to-authoritative rollout, threshold notifications and versioned bundle distribution with last-known-good semantics (section 10).
6. A **durable, priced, per-request usage record** that drives chargeback and analytics, alongside the per-model counters that drive budgets (section 11), together with **production evidence, an overhead benchmark** and the lessons we would carry to similar systems (sections 13 and 14).

The gateway governs which *models* an AI client may call. A companion platform, the Cosmos.AI MCP Hub [23], governs which *tools* it may reach over the Model Context Protocol [14]. Together they form the access and control plane for enterprise AI at PayPal.

2 Requirements

We derived the requirements from the failure modes above and from the operating constraints of a regulated financial-services company.

R1 One API, approved models. Clients use APIs they already know (OpenAI Chat Completions, Responses and Embeddings, Anthropic Messages, and Gemini generateContent) and reach approved models through the conversion paths the registry declares (table 3). Changing the vendor or region behind a model is a gateway change, not an application change.

R2 Brokered credentials. Clients present only an internal credential: a personal access token for developers, an application credential bound to a registered application for business applications, or a platform-minted token (section 8). The gateway obtains the upstream vendor credential, attributes its use to the calling user or application, and never returns it to the client.

R3 Identity-aware policy. Every request made on behalf of a person is checked against the caller's current position in the organizational hierarchy, so model restrictions and budgets follow people through reorganizations.

R4 Configuration, not deployment. Onboarding a model, changing a price, or adding a budget, restriction or notification is a validated data change.

R5 Streaming-safe performance. Translation and metering must not buffer streamed responses or add material time-to-first-token. Gateway overhead must be small and stable under load.

R6 Data protection. Where a use case's data classification requires it, the gateway applies detection to prompts and blocks, redacts or pseudonymizes detected personal and payment data before it reaches an external provider, with policy set per use case.

R7 Explicit failure semantics. Access control and data protection fail closed; observability fails open; an invalid configuration prevents startup instead of serving incorrectly.

R8 Connections, not only requests. Long-lived real-time sessions (voice calls of up to 30 minutes) must survive deployments, autoscaling and node upgrades.

R9 Attribution by default. Every governed request is designed to produce a durable, priced usage record attributable to its calling principal (a user or a registered application) and, where present, to a platform and workflow, with no application instrumentation.

R10 No big-bang migration. Hundreds of applications were already in production. Any plan that required every team to update its integration was not acceptable.

3 Background and Related Work

Programmable proxies. Envoy [6] is a widely deployed layer-7 (L7) proxy with mature TLS, HTTP/2, WebSocket, load-balancing and telemetry support. It offers two extension mechanisms that matter here. The *external processing* filter (ext_proc) [7] streams request and response phases to a gRPC service that may inspect and mutate headers, bodies and trailers and may return an immediate response; it runs

out of process and can be configured to fail open or closed. *Proxy-Wasm* [21] runs sandboxed WebAssembly modules inside the proxy's worker threads, which suits per-byte work on streaming bodies.

LLM gateways. Open-source LLM proxies provide a unified API across vendors, typically as an application-level service [20]. Agent Router (formerly Envoy AI Gateway) [1] and agentgateway [2] build AI-specific routing on top of proxy data planes, and cloud providers now offer managed AI gateways [5, 13]. The closest design to ours, Agent Router, performs request translation, upstream authorization and token metering in an external processor, and names Envoy dynamic modules as a possible higher-performance alternative [1]. A single streamed response can carry thousands of chunks, and we did not want to pay a network round trip to an external process for each of them. We therefore keep only I/O-bound decisions out of process and run per-chunk translation and metering in-proxy as WebAssembly (section 5). We evaluated an off-the-shelf proxy before building. Basic routing worked, but at the time of evaluation it did not meet our requirements for real-time (WebSocket) traffic, identity-aware authorization, enforceable user- and organization-level budgets, or workload-identity-based cloud credentials. Our design shares the proxy-native approach of these projects. It differs mainly in the governance layer: organization-anchored policy, retroactive spend scopes, and a managed policy lifecycle.

Authorization and policy as code. Zanzibar [19] established relationship-based authorization at global scale. Open Policy Agent (OPA) [17] popularized declarative, side-effect-free policy evaluated against injected data. We use OPA as the decision engine. The gateway gathers state and performs effects, which keeps decisions pure, testable and replayable (section 9).

Cost-aware model use and serving. FrugalGPT [4] and RouteLLM [16] route queries across models to trade cost against quality. Serving systems such as vLLM [12] and SGLang [24] optimize inference itself. These lines of work complement ours: a gateway is the natural place to enforce the budget decisions that a router optimizes for, and it sits above the serving systems that host open-weight models.

4 System Overview

Figure 1 shows the system. A single TLS listener terminates all traffic and routes it by path through the same Envoy pod. Unified API requests pass through the control path (authentication, policy, data protection and credential brokering), translation and metering in the Wasm filter, and an upstream call with a brokered credential (section 5). Real-time voice APIs run over WebSocket; for these, Envoy holds each long-lived connection on its event loop and forwards audio frames as they arrive, without body buffering (section 12).

Behind the data plane sit three supporting planes. The *control plane* holds the authoritative model registry, prices and governance policy, exposes a management API for platform and business-unit (BU) administrators, and publishes versioned policy bundles. The *identity plane* mints verifiable JSON Web Tokens (JWTs) for platforms that call the gateway on behalf of users. The *telemetry plane* carries metrics, traces and durable per-request usage records into the analytics warehouse.

Setting	control ext_proc	metrics ext_proc
Failure mode	fail closed	fail open
Request headers	send	send
Request body	buffered	streamed (mirrored)
Response headers	skip	send
Response body	none	streamed (mirrored)
Response trailers	send	send
Blocking	yes	no (observability mode)
Dynamic metadata	attribution, cost	–

Table 1: Default ext_proc processing modes. Response bodies never wait on an out-of-process call unless a use case's data-loss-prevention policy requires response handling (section 8).

Deployment. The gateway runs on Google Kubernetes Engine (GKE) in multiple regions with disaster recovery. Closed-weight models such as Gemini and Claude are served, where supported, through the global endpoint of Google's Gemini Enterprise Agent Platform (formerly Vertex AI Platform), which avoids dependence on a single regional endpoint. Open-weight models run on an internal GKE inference stack built on vLLM [12], SGLang [24] and NVIDIA Dynamo [15]. Other providers are reached over the network with brokered credentials. The caller does not need to know where a model runs.

5 Data Plane: Two-Tier Extensibility

5.1 Splitting work by latency profile

The most consequential design decision was to refuse the trade-off between *governed* and *fast*. Governance decisions are I/O-bound: they need identity validation, the organizational hierarchy, spend counters and secret material. They therefore run out of process in a Go ext_proc service that scales independently of the proxy. Payload work is CPU-bound, sits on the critical path of every streamed byte, and needs no network I/O. It therefore runs inside Envoy as a Rust Proxy-Wasm filter, so that a streamed response is translated and metered chunk by chunk without waiting on any out-of-process call.

Below, the *control service* is the Go service behind the control ext_proc, the *metrics service* is the service behind the metrics ext_proc, and the *Wasm filter* is the in-process translation filter (translate.wasm in fig. 1). The HTTP filter chain runs in a fixed order: (1) the control ext_proc, configured to fail closed, which receives the buffered request body because the routing key (`model`) is in the body; (2) a metrics ext_proc, configured to fail open, which runs af-

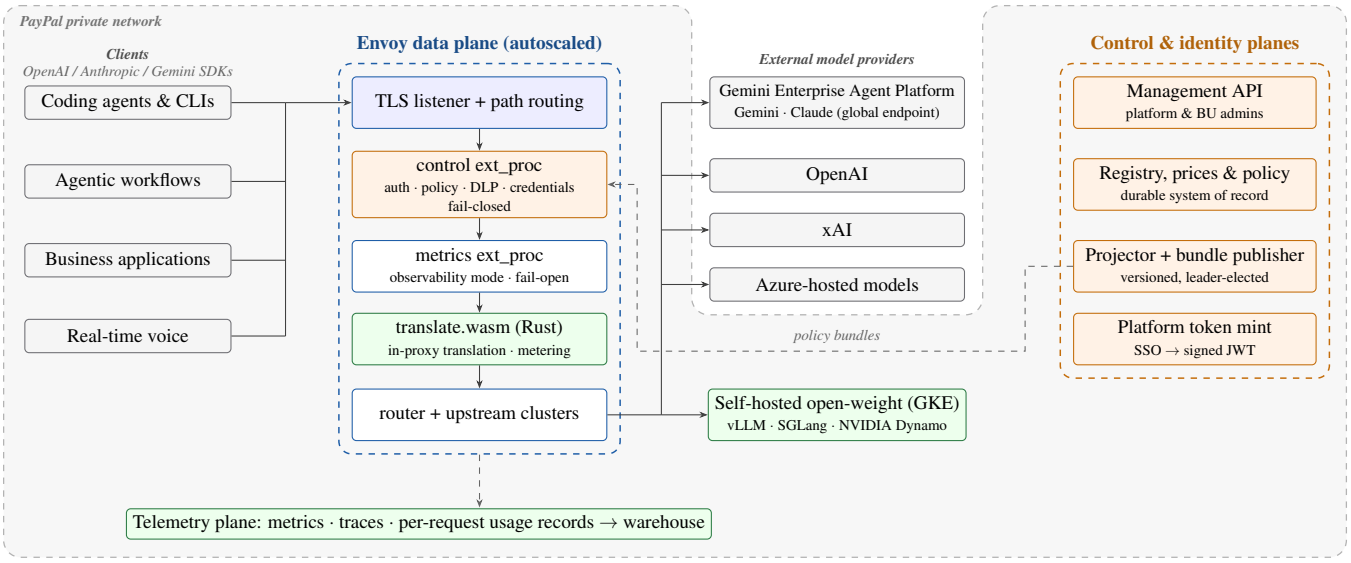

Figure 1: Architecture. One governed entry point fronts enterprise LLM traffic. On the unified API, the control service makes I/O-bound decisions out of process and fails closed, and the Wasm filter translates and meters in process. Real-time sessions use a connection-oriented path tuned for long-lived streams. The control plane publishes versioned policy bundles that the data plane enforces on every request. The shaded region is PayPal's private network: self-hosted open-weight models run inside it, and external providers are reached with brokered credentials.

ter control and therefore observes the request as authorized and rewritten; (3) the translation Wasm filter; (4) a small buffer filter that restores `Content-Length` after translation, because some upstreams reject chunked request bodies and Proxy-Wasm cannot set headers during the body phase; and (5) the router. Table 1 lists the ext_proc processing modes. The metrics service runs in Envoy's *observability mode*, in which bodies are mirrored to it asynchronously and never held. The control service buffers only the request body, skips response headers and bodies entirely, and is invoked again only for response trailers, where it reads usage. By default, the streamed response body therefore sits on the blocking critical path of exactly one extension, the in-process filter; the metrics service sees a non-blocking mirror, and the control service is consulted again only for the trailers at the end of the stream. In production, the metrics service derives metrics from mirrored bodies without persisting their content.

5.2 Request lifecycle

Figure 2 traces a unified request. In the *request-headers* phase the control service records the entry wire format (from the path) and the caller's credential; Envoy then delivers the buffered, size-bounded body. In the *request-body* phase it authenticates the caller, extracts the model, resolves it through the registry, evaluates model access, brokers the upstream credential, evaluates rate and spend policy, sets the handoff headers for the Wasm filter, rewrites the path, and asks Envoy to clear its route cache so that Envoy re-selects the vendor route and cluster for the rewritten request. It also attaches attribution metadata for the access log. The Wasm filter then translates the request into the upstream format. On the response, the filter translates each chunk back into the client's format, taps token usage from the stream, and emits usage as response trailers. In the *response-trailers* phase the control service prices the request from the registry, records spend, attaches cost metadata, and invalidates a cached upstream credential if the vendor returned 401 or 403.

5.3 A contract between two languages

The Go control service and the Rust filter communicate only through a small, versioned contract of gateway-internal request metadata and response trailers, which carry the entry and upstream wire formats, the upstream model, token usage, a count of unclassified fields and the tools the model invoked. The contract lives in one machine-readable file that also names the access-log metadata fields (section 11). Test suites in both languages assert their constants against it, so any drift fails the build, and an unrecognized value is never reinterpreted. In practice, this explicit cross-language contract removed a class of integration bugs that otherwise surfaced only in end-to-end tests.

5.4 Failure semantics

Each component on the request path had to answer one question: *if this breaks, what happens to the request?* Table 2 summarizes the answers. The asymmetry is deliberate. An access or data-protection rule that silently stops enforcing during an outage is not a rule, so those decisions fail closed. A telemetry outage must never become a traffic outage, so observability fails open. New budgets are rolled out in shadow mode first, which is designed to keep a defect in a newly introduced policy from taking AI tooling offline for the whole organization. Together these rules make degradation graceful and predictable: telemetry failures never reach

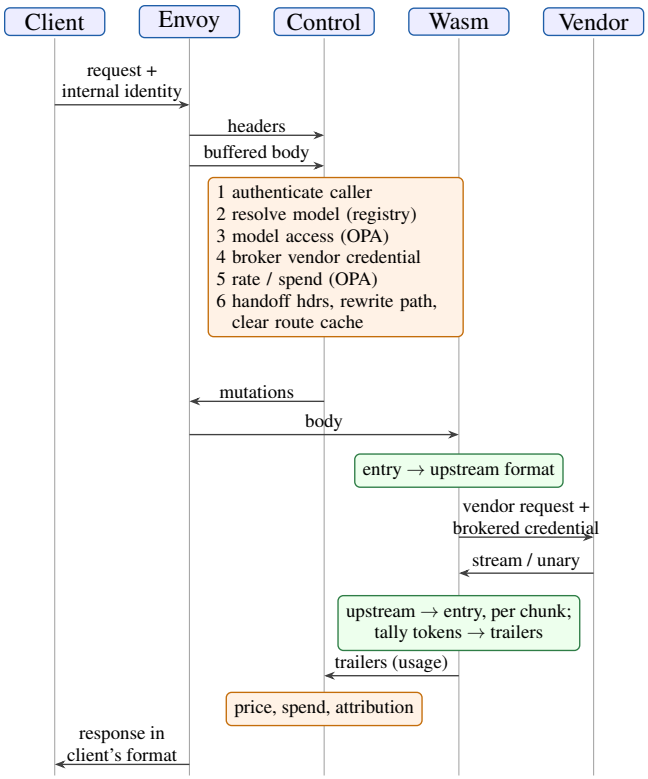

Figure 2: Lifecycle of a unified request. Routing decisions happen in the body phase because the model is in the body. Streamed response bytes pass through only the in-process filter on the critical path.

the caller, a failed policy update leaves the last good revision in force, and an invalid configuration is rejected before it serves traffic.

6 Models, Routing and Pricing as Validated Data

Early versions encoded vendor selection, upstream paths and capability flags in code. That made every new model a deployment, and nothing could be edited by an administrator. We replaced it with a *registry*: a typed, declarative model of everything the gateway supports. Model resolution, upstream paths, capability gating and prices all come from the registry. The code keeps a path-template substitutor, the credential resolvers (which perform I/O), and a small number of provider-specific adaptations for vendor quirks, such as session-affinity headers.

Entities. The registry defines *brands* (who makes a model), *API families* (chat, responses, embeddings), *wire formats* (e.g., Anthropic Messages, OpenAI Chat, OpenAI Responses, Anthropic-on-Vertex, Gemini generateContent), *credentials* (how a provider authenticates, holding secret *names* and never values), *providers*, *clusters*, *provider operations* keyed by (provider, deployment format, API family) that map to a path template and streaming mode, *models* (with aliases, tags, entry formats and access metadata), *deployments* (physical serving locations with region, priority and price), *entry routes* and *converters* (legal translation pairs).

Failure	Behavior
Control service unavailable	Request rejected (fail closed)
Access-policy evaluation error	Deny
Spend-policy evaluation error	Deny when enforcing; logged in shadow mode
Data-protection check cannot complete	Request not sent (fail closed)
Invalid registry / policy at boot	Process refuses to start
Policy bundle reload fails	Keep last-known-good revision
Metrics service unavailable	Traffic unaffected (fail open)
Client reset mid-stream	Usage record still written (section 11)

Table 2: Failure semantics on the request path.

Resolution. For a request with entry path p and model identifier x, the data plane computes:

```
entry  = entry_routes[p].format
model  = resolve(x)              # canonical id or alias
family = model.upstream_family or family(entry)
dep    = model.deployment_for(entry)
op     = operations[(dep.provider, dep.format, family)]
up_fmt = canonical(family) or dep.format
require converter(entry -> up_fmt)   # identity or declared
path   = substitute(op.path, dep)    # project, region, model,
    verb
cred   = providers[dep.provider].credential
```

Capability gating is therefore data. If no responses-family operation exists for a provider, that provider does not support the Responses API, and no code needs to check for it. An optional per-model `upstream_family` pins the vendor surface when the client's family would choose the wrong one. For example, a coding agent may speak a chat-family API while the vendor requires its responses endpoint for tool use combined with reasoning.

Pricing as configuration. Each deployment carries its price in USD per million tokens for input, output, cache reads, cache writes and extended-lifetime cache writes. A price may also define a *long-context tier* that applies when the prompt (input, cache-read and cache-write tokens) exceeds a threshold. For a request with token counts n_k and the applicable tier's rates p_k, the cost in micro-dollars is $\sum_k n_k p_k$. A price change is therefore a registry edit that takes effect within one publication cycle, and the management API validates prices on every write: units come from an allow list, every rate is non-negative, and unknown keys are rejected.

Fail-closed validation and the serviceability invariant. The loader turns raw configuration into a typed registry or returns an aggregated error that aborts startup. It checks that every reference resolves, that credential kinds match their providers, that operations and aliases do not collide, and that

	Upstream format			
Entry format	**OAI Chat**	**OAI Resp.**	**Anth.@Vertex**	**Gemini**
Anthropic Messages	T	T	R	T
OpenAI Chat	T*	T	T	T
OpenAI Responses	–	I	–	–
Gemini generateContent	–	–	–	I

Table 3: Conversion plan by entry and upstream format: OAI = OpenAI. I = identity, R = raw envelope rewrite, T = translation through the IR, – = not offered (by registry configuration, not code). *Vertex* denotes the Gemini Enterprise Agent Platform API. *Same-format round trip that preserves Gemini tool-call thought signatures (section 7).

the following invariant holds:

$$\forall m \in \mathscr{M},\ \forall f \in \text{entry}(m) : \exists d \in \text{dep}(m) : \\ \text{op}(d,f) \neq \bot \ \wedge\ \text{conv}\big(f, \text{up}(d,f)\big).$$

In words, every format a model advertises is backed by at least one deployment that has both an operation and a converter. The model-discovery endpoint is rendered from the same registry, so discovery and routing cannot disagree. Appendix A gives an abridged registry excerpt.

Admission and discovery. Model discovery is rendered from the registry, and its visibility is configurable per model. The caller is authenticated before the model is looked up, and unknown and policy-denied models return the same response (HTTP 404, "model not found or not available"), so the API does not reveal whether a hidden or limited-access model exists. The specific reason is recorded server-side, in logs and audit reason codes, for operators.

From file to database. The registry began as a version-controlled file and now has a durable store behind the management API (section 10.1). A leader-elected projector rebuilds the served registry deterministically whenever the store's epoch changes and publishes it through the same bundle channel as policy (section 10). The data plane validates the projected registry when it loads it; an invalid or missing bundle fails configuration. Registry and policy epochs are independent, so a catalog change never requires rewriting policy rules, and vice versa; registry and access data are published in the same bundle.

7 In-Proxy Translation

A canonical IR: N codecs, not $N(N-1)$ converters. Every wire format decodes into, and encodes out of, one canonical intermediate representation (IR). An any-to-any conversion is *decode* $\rightarrow$ *IR* $\rightarrow$ *encode*. Each codec translates only between the IR and one wire format, with no knowledge of other formats, so adding a format costs one codec rather than one converter per existing format. The system has five general-purpose codecs, plus raw adapters for a small number of internal formats.

Three conversion plans. Building the IR is necessary only when the envelope cannot simply be rewritten. The converter chooses among:

- **Identity**: source equals target, and bytes pass through unchanged.
- **Raw**: same family with a different envelope (e.g., Anthropic Messages to Anthropic-on-Vertex). The message content is kept verbatim and only envelope fields are rewritten (plus the gateway's cache breakpoints), which preserves vendor-only fields such as cache control and extended thinking that an IR round-trip might drop.
- **Translate**: a full decode–IR–encode, for example from Anthropic Messages to OpenAI Chat.

Both fast paths are lossless for client content because they never build the IR. Table 3 shows the plan for the main entry and upstream pairs. OpenAI Chat to OpenAI Chat is a deliberate exception to identity. Gemini, served through an OpenAI-compatible chat endpoint, returns a `thought_signature` [9] on each tool call (in a vendor extension field, `extra_content`) and requires it to be sent back on the next turn; some agent clients drop unrecognized fields when they echo the conversation, which would break multi-turn tool use. On the response, the codec therefore reversibly encodes the signature into the tool-call identifier, which clients must echo verbatim to correlate tool results. On the next request, it decodes the identifier, restores the original ID and reinstates the signature in the extension field before forwarding upstream. The mechanism is stateless and applies only to signatures attached to tool calls; the Anthropic Messages and OpenAI Responses codecs use the same identifier encoding.

Streaming. Server-sent event streams are converted incrementally. A decoder maps wire chunks to IR stream events (message start, content-block start, text and tool-argument deltas, block stop, usage, message stop), and an encoder maps those events to the target's event grammar. Per-stream decode and encode state carries partial bytes across chunk boundaries, maps the wire stream's content-block indices onto the IR's indexed blocks, and buffers nothing beyond an incomplete event. Reasoning signatures that some vendors require to be echoed on the next turn are carried through the IR, so multi-turn tool use survives a format change. Token usage is tapped from the stream and reported in trailers without altering the passthrough bytes. Because Proxy-Wasm forbids header writes during the body phase, all metadata produced while streaming leaves the filter as trailers.

Schema drift is a signal, not silent loss. Vendors evolve their APIs continuously. Request fields the codecs cannot classify are counted and surfaced as a trailer and a metric. In addition, a coverage test fails the build when a known field is unclassified, which forces a human decision instead of silent data loss.

Gateway-side prompt caching. Coding agents resend

long, stable prefixes (system prompts, tool definitions, conversation history) on every turn. The filter injects cache breakpoints on the last tool definition, the system prompt and the most recent content block, within the vendor's limit of four breakpoints [3] and without removing breakpoints the client already set, and it requests an extended (one-hour) cache lifetime for all of them. This shaping applies on the Anthropic-on-Vertex upstream path. For providers that support it, the control service can also add a stable, hashed session-affinity key derived from the caller's identity (and the client's session where available), enabled per provider or for a configurable share of traffic, so that repeated turns land on warm caches. Clients get these benefits without changing any code; the effect is reported in section 13.

8 Identity, Credentials and Data Protection

Inbound credentials. Every caller of the unified API presents an internal credential, never a vendor key. Developers use a personal access token tied to their corporate identity. Business applications present an application credential bound to a registered application, so that usage is attributed to that application rather than to an individual. Platforms that act on behalf of users present tokens from the mint service described below. Personal and platform-minted tokens resolve to a person, whom the policy layer evaluates against the organizational hierarchy; application credentials resolve to the registered application.

Outbound: brokered, keyless credentials. Clients of the unified API never hold a vendor key, so a leaked application configuration does not expose a vendor credential. The registry declares a credential *kind* per provider and the gateway resolves it per request: per-user upstream credentials brokered by the gateway, OAuth2 client-credentials grants for directory-backed providers, the gateway's own workload identity for cloud-hosted models, and, for application traffic, a short-lived credential scoped to the calling application. Secrets are fetched at runtime from a managed secret store using the platform's own identity; secret values are not placed in code or static configuration, and request logging redacts credentials.

SSO-attested platform identity. Platforms that call the gateway on behalf of users, such as agent harnesses and internal developer platforms, need a trustworthy way to identify themselves and label workflows. We introduced a *mint* service that converts "a user signed in to platform *P* through corporate SSO" into a signed, time-bounded JSON Web Token (JWT) [11] naming the user, the platform and optional attribution tags (e.g., workflow and run). Its design choices are:

- **No shared platform secret.** A platform is identified by the OAuth client identifier bound to its OpenID Connect (OIDC) [22] flow. The mint service accepts only a verified `id_token` whose authorized party (or, when absent, audience) resolves to a registered, active platform. The identity provider issues such tokens only through that client's flow.
- **The user is the subject; the platform is an attribution dimension.** The platform cannot choose the subject. Spend is charged to the user's budget, and the platform appears on every usage record.
- **Offline verification.** Tokens are signed, with keys published through a JSON Web Key Set (JWKS) endpoint [10]. The control service verifies them locally, with no per-request call to the mint service.
- **Bounded lifetime.** Token lifetime is capped per platform and never exceeds the expiry of the presented identity token, so re-minting cannot extend access beyond what the identity provider issued.
- **Tags are attribution, never authority.** Tag keys are allow-listed per platform, size-bounded and rejected when unknown. They never expand routing, authorization or quota.
- **Authentication tokens do not persist.** The `id_token` and the minted token are never logged or stored. Every decision, including rejections, is audited by reason code.

Minted tokens can also carry a *workflow budget*, bounded at mint time and signed, that caps the total spend of a workflow across all of its users. It is enforced in addition to user budgets and can never bypass them.

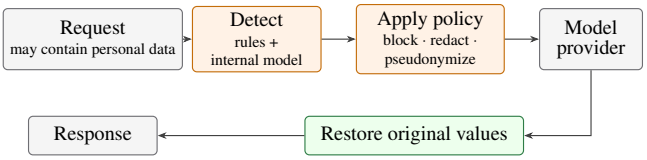

Figure 3: Data-loss-prevention flow. Detected sensitive content is blocked, redacted or replaced with format-preserving surrogates inside the enterprise boundary before the provider call; surrogates are mapped back in the response.

8.1 Data loss prevention

Prompts in a payments company can contain personal and payment data that should not reach an external model provider. For use cases whose data classification requires it, the gateway therefore applies a data-loss-prevention (DLP) layer on the request path (fig. 3).

Detection inside the enterprise boundary. Detecting sensitive data in free text is harder than matching patterns: the same date or number can be harmless in one sentence and sensitive in the next. Detection therefore combines deterministic pattern rules with an internally hosted, purpose-trained detection model that uses the surrounding context. Both run inside the enterprise boundary, so content is inspected before any vendor call is made. Detection is probabilistic, and accuracy varies by entity type. DLP therefore reduces exposure rather than guaranteeing that no sensitive value is ever

sent, and it complements, rather than replaces, use-case data classification and provider contractual controls.

Policy-driven actions. Each use case is configured with its own DLP policy, because data classification, security zone and tolerance for false positives differ between use cases. From most to least restrictive, a policy can *block* a request that contains sensitive data; *redact* the sensitive spans by masking or removing them; or *pseudonymize* them, replacing each value with a realistic surrogate of the same format and restoring the original values in the response. For these use cases the gateway also handles the response body: the original values that were swapped out are held for the duration of the request and substituted back for their surrogates before the response is returned to the client. Redaction is simple but can distort the task (a model asked to apply an age-based rule cannot reason about a masked date). Pseudonymization preserves the format of each detected value while the provider never sees the detected originals, which makes it well suited to conversational use cases.

Operational properties. DLP is integrated into the gateway API and is enforceable per use case: an application adopts it through per-use-case configuration and a request-level enforcement flag rather than an extra service call or SDK change. Inspection fails closed: if a check cannot complete, the request is not sent. DLP events are logged for security monitoring and audit. Together with a mediated path, attribution and consistent usage records, these are technical controls that can contribute to the organization's broader compliance programs; the gateway does not by itself establish compliance with any regulatory framework.

9 The Policy Model

Governance answers three independent questions: *who may use which model*, *how much may be spent*, and *how fast*. The policies in this section govern person-attributed traffic: developers, and users acting through platforms. Application traffic is governed through its application registration and attributed by application identifier in the usage record (section 11).

9.1 Model restrictions and access layers

Access is layered (table 4). Each access layer can only narrow what the layers above it allow (an authoritative pilot's cohort lists decide access for its enrolled users, section 10.2), and each is evaluated before any vendor credential is issued. Spend caps work differently: an approved business-unit override can raise a platform cap, but only within the platform's locks (sections 9.2 and 10.2). Model restrictions name organization *leaders* rather than teams: a model may carry a leader deny list, an optional leader allow list, and explicit per-person exemptions. A caller belongs to a leader's organization when that leader appears in the caller's upward reporting chain. The chain is resolved from the people directory through a cache, with the organization snapshot distributed in the policy bundle as a fallback (section 10). Because rules name leaders rather than team lists, a reorganization that moves a team automatically moves its access and budgets, with no policy edits.

Layer	Set by	Effect
Catalog admission	platform (registry)	unknown model → 404
Model restriction	platform admin	leader allow/deny lists and exemptions → 404 (same as unknown)
BU allow/block list	platform admin	a model is open to, or closed to, named business units
BU model toggle	BU admin	switch a model off for one's own BU; cannot override a platform lock
Limited access	platform admin	bounded named roster with its own spend controls and expiry
Pilot cohort	platform admin	date-bounded allow/restrict lists per cohort

Table 4: Access-control layers. Each layer narrows the access granted by the one above it, except authoritative pilot cohorts (section 10.2); spend caps are separate and can be raised within platform locks (section 9.2).

9.2 Spend: scopes are views, not storage

Let $\mathscr{M}$ be the set of canonical model identifiers and $\tau : \mathscr{M} \to 2^{\mathscr{T}}$ assign each model a set of tags from $\mathscr{T}$, the set of registry tags, along several axes: everything, vendor, model family, license class (proprietary or open-weight), or any operator-defined axis. A *scope* s is a tag or a single model, and resolves to $\mathscr{M}_s = \{m : s \in \tau(m)\} \cup (\{s\} \cap \mathscr{M})$. For budgeting, spend for user budgets is accumulated *only* as counters $c(u, m, \omega)$ in micro-dollars, keyed by user u, immutable model identifier m and window instance ω (daily, weekly or monthly, on a single fixed calendar timezone for all regions). Here u ranges over people; application traffic is attributed by application identifier (section 11), and workflow budgets (section 8) are accumulated in counters of their own.

A budget rule consists of one or more *entries* $e = (P_e, s_e, w_e, \theta_e, A_e)$, each with a population predicate P_e (user tiers, organization leaders, business unit, cohort and exemptions), a scope, a window, a threshold and a set of actions. Rules carry a precedence weight, and entries are ordered by it. The utilization of entry e for user u at time t is

$$\rho_e(u,t) = \frac{1}{\theta_e} \sum_{m \in \mathscr{M}_{s_e}} c\big(u, m, \omega_{w_e}(t)\big).$$

For a request by u for model m^*, the request is *blocked* by the first entry, in precedence order, that has a block action, satisfies $P_e(u) \wedge \rho_e(u,t) \geq 1$, covers the requested model ($m^* \in \mathscr{M}_{s_e}$), and is not *superseded*. Otherwise it is *paused* by the first matching entry with an active pause that covers m^*. Scoping blocks to the requested model means a cap on one model family stops only that family: a user who exhausts a frontier-model budget can keep working on other

models. A platform entry is superseded for a user when an approved business-unit override for that user's BU covers the same window and scope with a *higher* threshold, so an approved BU increase outranks the platform baseline for that BU only. Separately, the *governing* limit reported to the user is the block or pause entry with the highest utilization.

Actions compose. *Block* is stateless and recomputed per request, so it clears automatically when the window rolls over. *Pause* blocks for a fixed duration and fires at most once per rule and window, so a user who returns hours later is not penalized again. *Message* adds a live status line, and *email* notifies the user or, as a deferred digest, the leadership chain (section 10.3). A separate *no-promote* action can bar a population from self-service tier promotion (section 9.3).

This formulation has a property that matters operationally. Because tags are resolved at evaluation time over counters keyed by immutable model identifiers, **a newly created tag or rule immediately governs spend recorded earlier in the current window, before the rule existed**. No backfill, key rewrite or migration is needed. A business-unit policy such as "cap each person in this BU at a monthly amount for Opus-class models" (a vendor's largest model family) is a single data change that takes effect over the month to date. Business-unit policies are entries whose population predicate selects that unit; their caps apply per person (section 10). Retroactive *scope* is not retroactive *repricing*: counters are already denominated in micro-dollars at the price in force when each request completed, so a later price change affects only subsequent requests. The same property lets a draft rule be dry-run against current usage before it is enabled (section 10). Appendix B shows the rule language.

Rate limits and workflow budgets. Per-minute rate limits are available to protect shared upstream quotas. Workflow budgets (section 8) apply in addition to user rules, and whichever limit trips first blocks.

9.3 User tiers and self-service promotion

Users belong to one of three tiers with progressively larger allowances, derived from enterprise entitlement roles. Promotion is self-service through an internal access workflow. Promotion is subject to usage-based eligibility, and promotions expire automatically. Any budget entry can also carry a no-promote gate, either unconditionally for a population or only while the requesting user's own spend in a scope is at or above a threshold, so leadership can pause promotions for an organization without editing user records.

9.4 A pure decision function

We moved policy evaluation from imperative code to OPA [17] and its policy language, Rego. The dividing line is strict: **the gateway gathers state and performs effects; Rego decides**. Before evaluation, the control service assembles an input document containing the caller, canonical model, tier, organization chain, the summed spend per (scope, window), pause state, window boundaries and the enforcement switch. Evaluation returns a decision (block or allow, the limiting entry, a retry-after hint and per-limit utilization). The gateway then performs any side effects: updating counters, recording pauses and one-shot notifications, and queuing emails. Listing 1 gives a simplified illustration.

```
package gateway.spend
import rego.v1
import data.gateway.util

# entries that apply to this caller (tier, org, BU,
# cohort, exemptions), with utilization in percent
applicable contains entry if {
  some e in data.gateway.entries
  util.population_matches(e, input)
  pct := util.pct(input.spent[e.scope_window], e.threshold)
  entry := object.union(e, {"pct": pct})
}

blocking := util.first_by_precedence([e |
  some e in applicable
  some a in e.actions
  a.type == "block"
  e.pct >= 100
  util.covers(e.scope, input.model)
  not util.superseded_by_bu_override(e)
])

decision := {"block": true, "limit": blocking.id} if {
  input.enforce
  blocking
} else := {"block": false}
```

Listing 1: Simplified, illustrative spend decision in Rego (not the production policy). Spend sums are supplied by the gateway; the policy only decides. In shadow mode nothing blocks, but utilization is still computed and reported.

The policy is organized into isolated modules: access, spend, rate limiting, alerts, pilots, validation, shared utilities and read-only administrative queries. The pilot module is deliberately isolated from platform and BU policy documents, and the policy test target checks that separation. On the request path, an enrolled pilot decision overrides the platform and BU decision only when pilot enforcement is authoritative.

Keeping decisions pure gave us four practical benefits. Policies are unit-testable, and the policy suite requires coverage of every production module. A "what-if" admission query can preview a proposed change without touching live state. The policy and organization data are distributed as a versioned bundle (section 10), so every data-plane replica evaluates the same revision. And the migration itself was safe: the previous Go engine and the OPA engine ran side by side behind a selector while a parity suite checked identical decisions across all combinations of engine and enforcement mode, together with hot-reload tests of updated rules.

10 The Governance Control Plane

A policy engine is useful only if the right people can change policy safely. The control plane turns models, prices and policy from engineering artifacts into an operated product

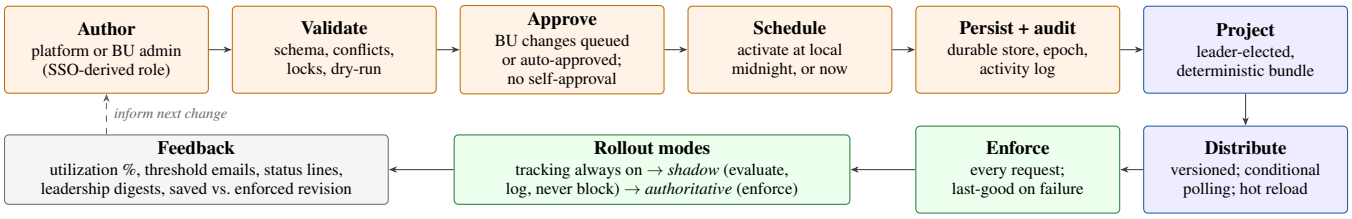

Figure 4: Policy lifecycle. Intent is authored and validated against the same rules the data plane enforces, approved when it originates from a business unit, persisted with an audit record, projected into a versioned bundle, and enforced on every request. New controls are rolled out in shadow mode before they block.

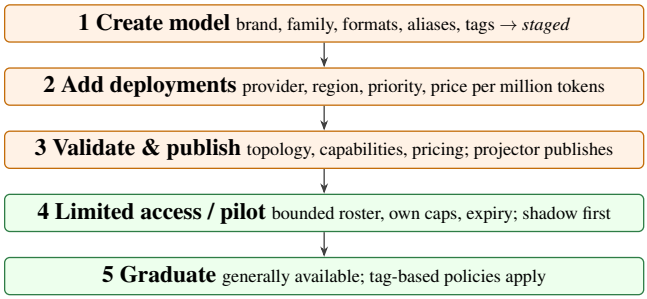

Figure 5: Model onboarding through the control plane: each step is a validated, audited data change; no code release is involved.

(fig. 4).

Roles and trust. Administrators authenticate through corporate single sign-on, and the gateway maps each administrator onto one of two canonical roles. *Platform administrators* act organization-wide. *BU administrators* act only within the business units they have been granted.

10.1 Model onboarding lifecycle

Onboarding a model is a sequence of validated data changes through the management API (fig. 5). A platform administrator creates the model (brand, API family, entry formats, aliases, tags, capabilities) and then its deployments, each with provider, region, priority and price. Every write is validated against the registry topology, capability and pricing rules; updates and deletes require an entity-tag precondition (missing returns 428, stale returns 409), and an idempotency key makes retries safe. Until it has an enabled deployment, a model is *staged* and not served. A new model can first be released as *limited access* to a bounded named roster, with its own spend windows, amounts and expiry, or through a pilot. It is then *graduated*, which clears the roster and makes the model generally available. Because policies can select models by tag, a newly tagged model is covered by existing restrictions and budgets within one publication cycle, with no policy edit. A model cannot be deleted while a live policy references it, and every step is recorded in the activity log.

10.2 Platform and business-unit policies

Platform policies set organization-wide controls: per-person runaway-cost limits, per-model caps, model-access decisions, and *locks* that BU policies cannot exceed. Conflict checks scan the complete active set before a change is accepted, and caps must be strictly ordered across windows (a monthly cap exceeds the weekly cap, which exceeds the daily cap).

BU policies let business-unit administrators set per-person and per-model caps and model toggles for their own organization, within the platform's locks: an unlocked BU cap takes precedence over the platform baseline, a request above a locked maximum is rejected (and any stored cap is clamped to that maximum when policies are applied), and an exact lock rejects any change. BU model toggles take effect without approval but cannot re-enable a model the platform has locked. Controls can select models explicitly or by tag, and tag selections follow the registry.

Approvals and scheduling. BU cap changes are either submitted to an approval queue, where they do not affect enforcement until approved, or auto-approved where the platform allows it. Decisions are restricted to platform administrators, self-approval is forbidden, a rejection must include a comment, and an approval can be bound to the reviewed diff so that edits arriving in between are detected. Changes can be scheduled to activate at midnight in a given timezone. A leader-gated scheduler applies them, expires stale requests, and re-projects whenever the store's epoch is ahead of the served bundle, so the durable record and the enforced bundle converge.

Pilots. New models and new budget regimes are introduced through *pilots*: named, date-bounded programs of a small number of cohorts. Each cohort has its own cost controls, model-access lists, BU assignment, alerts and exceptions. Cohorts that share a leader and window but have distinct amounts form a *tier ladder*. An enrolled user is governed by the lowest tier whose exceptions do not cover them, so an exception promotes a user up the ladder rather than removing the cap. Validation returns every violation at once (double enrollment, duplicate controls, duplicate tier amounts, unknown or empty tag selections), and writes serialize across replicas under a database advisory lock. Pilot enforcement has its own switch: *off*, *shadow* (evaluate and log only) or *authoritative*.

10.3 Usage notifications and reminders

Users should learn that they are approaching a limit long before they hit it. Notification points are configurable at two levels. In the rule language, any entry can attach an email

or status-line action at its own threshold; the typical pattern is a warning email at 90% of an allowance and a block plus email at 100% (appendix B). In managed policies, each control carries alerts at administrator-chosen percentages (1–100%), each with at least one channel (email or in-tool message) and a template. Templates are managed through the API, are scoped to the platform or to a business unit, and support placeholders such as utilization percentage, threshold, resume time, model, window, person and business unit. Delivery is deduplicated per policy owner, window instance, threshold, template and channel, so a user receives one email per crossing rather than one per request. Status headers on every response report the governing limit's utilization, status, scope, reset time and any pause, and coding agents and the developer CLI render them as a live status line. Leadership notifications are deferred into one digest per leader after the window boundary. The usage API reports utilization as percentages.

10.4 Rollout, distribution and audit

Shadow first. Usage tracking is always on, and enforcement is a separate switch, set globally and per pilot. New controls are therefore rolled out in shadow mode against real traffic, with utilization visible to users and administrators and nothing blocked, until their effect is understood. Because scopes are views over current-window counters, a draft rule can also be dry-run against current usage before it is enabled. A rule enabled directly while enforcement is on applies to the window to date and can block at once, which is why new controls go through shadow mode or a pilot first.

Distribution. The durable store is the system of record. A leader-elected projector builds a deterministic bundle containing policy, registry-derived access data and the organization snapshot, and serves it with an entity tag. Data-plane replicas poll conditionally and hot-reload. A failed reload keeps the last good revision, and an engine whose initial bundle fails to compile refuses to serve. API responses distinguish the *saved* revision from the *enforced* revision, so administrators can see when a change is live.

Audit. Every mutation writes an append-only activity record; policy changes write it in the same transaction as the change. Records can be filtered by category, outcome, actor and role; platform administrators see all records, and BU administrators see their own business units.

11 Telemetry, Metering and Attribution

Metrics and traces. Envoy's native statistics (upstream health, circuit breakers, connections, latency and response classes) and application metrics (requests, latency, token counts by kind, cache reads and writes, cost, rate-limit events, and schema-drift counts) are exported through OpenTelemetry [18]. Labels identify the canonical model, vendor and entry path, and aliases collapse to canonical identifiers so that each logical model is counted once. Per-caller dimensions are limited to a small set of governance events (such as limit blocks); full per-request attribution lives in the usage record, which keeps metric cardinality bounded and identity data in an access-controlled store.

The access log as the system of record. We initially emitted usage events from the control service through an asynchronous in-memory queue. That design lost data silently: when the queue was full, after retries were exhausted, during pod shutdown, and when a client disconnected before the trailers arrived. We moved the durable record to Envoy's access log, which Envoy writes for *every* stream, including resets, immediate rejections and control-service outages. The control service contributes attribution (user, application, tier, platform, workflow, harness, requested and canonical model, entry and upstream formats) and the priced cost breakdown as metadata assembled from in-memory state only. Assembling this metadata adds no I/O to any ext_proc phase. The Wasm filter contributes per-field token counts as trailers. Interrupted streams still produce a usage record. Blocked requests (4xx immediate responses for authentication failures, invalid requests, access denials and limits) carry the same attribution, which makes rejected traffic visible to abuse and chargeback analysis. The earlier event pipeline was run in parallel during migration so the two could be reconciled.

From log line to warehouse. Each record is one JSON line on standard output. A node-level logging agent ships it to a managed log service, from which the records are routed to the analytics warehouse. Rows are projected into a typed usage table, partitioned by day and clustered by caller and model, and a view deduplicates on the gateway-generated request ID, which clients cannot spoof. From the logging agent onward, delivery is at-least-once with read-time deduplication, barring node loss. Once a line reaches standard output it sits on node disk under the container runtime's management, so a crash of the gateway process afterwards does not lose it. The residual loss window is bounded: a hard proxy crash can lose at most one flush interval of buffered entries (below), and a node failure can lose seconds of unshipped agent buffer. This replaced the unbounded, silent loss modes of the earlier in-process queue. The schema is additive-only and versioned, so new fields require no infrastructure change. These records, one per request with tokens and cost by component, drive chargeback and usage analytics. Appendix C lists the fields.

Implementation details that mattered. First, Envoy silently *drops* dynamic metadata returned by an ext_proc service unless the filter allow-lists the receiving namespaces. Without the allow list, every metadata-derived column is null, and only an end-to-end test against a real Envoy caught it. Second, Envoy is configured to flush access-log entries

every few seconds for streams that are still open, rather than only when a stream closes, which bounds what a hard proxy crash can lose on a long stream at negligible I/O cost. Periodic entries preserve the record and its attribution; usage is carried by the entry written when the stream ends. Third, Envoy is configured not to preserve client-supplied request IDs, so a client cannot poison the deduplication key.

Context-engineering signals. The Wasm filter reports which tools a model actually invoked. Combined with the tools a client declared, this lets the platform identify MCP servers and tools that a user keeps declaring across requests within a 24-hour session window but that the model never invokes, and return per-user recommendations with the estimated token savings per request of removing them.

12 Reliability and Real-Time Traffic

Voice changed the problem. Our previous gateway was built for short request–response exchanges behind a request-oriented L7 load balancer. Chat traffic suited it, because each request released its resources almost immediately. A voice call is different: one WebSocket held for the whole conversation and streaming audio in both directions. Two thousand concurrent calls of up to 30 minutes each pinned per-session resources for the life of the call in a service sized for sub-second requests. In addition, a load balancer that balances *requests* is a poor fit for long-lived *connections*. Envoy resolves both problems: a call becomes a connection multiplexed on Envoy's per-worker event loops, and connection lifecycle is a first-class proxy concept.

A connection-oriented path. Real-time routes are tuned for long-lived sessions: frames are forwarded as they arrive, with no body buffering and no request timeout, and an idle timeout reclaims abandoned connections. Real-time sessions are recorded in the same access log and proxy metrics as other traffic, and real-time model endpoints are available in more than one region.

Graceful, drain-aware deployments. Pods move for ordinary reasons: deploys, autoscaling and node upgrades. A chat request that dies in a rollout is a retry; a voice call that dies is a customer hung up on mid-sentence. Our shutdown sequence is designed around the longest call:

1. A pre-stop hook marks the proxy unhealthy through its admin interface, so the load balancer stops sending it new connections while existing ones continue.
2. The hook then polls the listener's active downstream connection count periodically and returns as soon as it reaches zero, or shortly before the grace period ends.
3. The termination grace period (one hour) is longer than the longest expected call, because a conversation can last 30 minutes and holding a pod open is preferable to cutting off a customer.
4. Rollouts add a new proxy pod before removing an old one (surge one, zero unavailable), a pod disruption budget keeps all but one of the minimum replicas available during voluntary disruptions, and the proxy tier autoscales horizontally in each region.
5. The gRPC services drain the same way: they report `NOT_SERVING` on their health endpoint and then stop gracefully within a shorter grace period of their own. Their rollouts surge a full replica set with zero unavailability, because a fail-closed dependency must finish draining before it stops.

With this sequence we have deployed more than ten times during live voice traffic, with zero dropped calls, while sustaining more than 2,000 concurrent calls.

Regional placement and failover. The gateway runs in multiple regions with disaster recovery and load balancing. Where a data-residency endpoint is configured for a vendor, it is the default. Automatic fallback to another endpoint is a single retry, limited to connection-level failures and service-unavailable responses; other errors are returned to the client rather than retried, which keeps retries from amplifying load during a vendor incident.

Migration without a big bang. The gateway reached its current form without asking any team to change its integration. First, Envoy was placed in front of the existing service, so nothing behind it changed. Then authentication, credential brokering, translation, spend and policy moved into the new data plane one capability at a time, behind the same entry point, following a strangler-fig pattern [8]. Progress was measured continuously, and the previous implementation is being retired capability by capability.

13 Evaluation

13.1 Gateway overhead

Method. We measured the latency the gateway adds with a Locust load generator (user ramp of 500 users/s, think time 0.5–1 s) against a synthetic upstream with a fixed 110 ms latency. Each instance has 4 vCPU and 8 GiB, split evenly between one Envoy pod and one control-service pod. Load steps use 1,000 and 2,000 virtual users. Every request carries a unique payload, and each load step runs for five minutes. *Overhead* is the time from the start of the client request to the start of the upstream response, minus the upstream service time, both recorded by Envoy at microsecond resolution; it therefore measures the request path up to the upstream call and excludes response-body work. We ran two and four instances with 1,000 and 2,000 virtual users (about 1,100 and 2,300 requests per second) against the unified chat-completions path.

Results. Table 5 and fig. 6 show two results. First, overhead remained *stable over the tested range*: doubling the request rate on two instances changed no percentile, and on four instances the 2,000-user figures were within 1 ms of the 1,000-user figures. Second, adding instances did not change

Instances	RPS	Overhead (ms)			Failed
		p50	p95	p99	
2	1,137	4	10	11	0
2	2,257	4	10	11	0
4	1,138	4	10	11	0
4	2,262	4	9	10	0

Table 5: Gateway overhead (time to the start of the upstream response, minus upstream service time) with a synthetic 110 ms upstream. RPS: achieved requests per second.

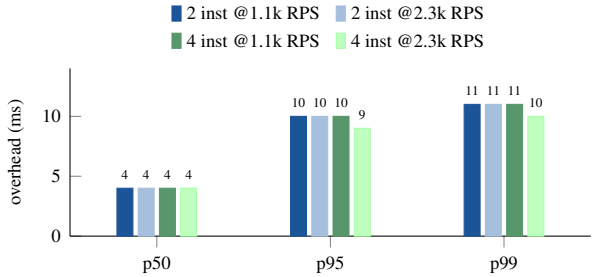

Figure 6: Overhead percentiles by instance count and load. Overhead was essentially unchanged when load or instance count doubled within the tested range.

overhead, which is consistent with a per-request cost rather than queueing delay at these rates. We did not test beyond 2,262 RPS and make no claim about behavior near saturation. No step produced a failed request.

Threats to validity. The benchmark measures the core request-handling path (caller authentication, model resolution, credential brokering and request rewriting) against a synthetic upstream; production overhead varies with the policies and features enabled for a workload. The load generator ran inside the same cluster, and all virtual users shared one credential, so caller authentication was served from the control service's in-process cache. The metric excludes response-body processing, which includes streaming translation. We make the methodology explicit so that others can reproduce it.

13.2 Production operation

Table 6 summarizes production operation as of September 2026. All figures are historical, point-in-time aggregates, not service-level commitments.

Effect of centralization. Several outcomes were not achievable under direct integration. Governed AI traffic now flows through one mediated entry point, and model calls carry per-user or per-application, per-platform and per-workflow attribution and a priced usage record. Model choice is configuration: switching the vendor or region behind a model requires no application change, and onboarding a new model or changing a price is a validated data change. Budgets are organization-aware, shadow-testable and retroactive within their window, and users are typically warned before they reach a limit. Engineers reach approved

Measure	Value
Developers using the gateway	12,000+
Production use cases	hundreds
Requests per day	millions
Tokens per day (all traffic)	∼200 billion
Models / model families / providers	100+ / multiple / multiple
Peak throughput from a single workload	60,000 req/min
Concurrent real-time voice calls supported	2,000+
Deploys during live voice traffic; dropped calls	10+; 0
Gateway prompt-cache hit rate (best workloads)	up to 96%
Availability to business (ATB)	99.999%

Table 6: Production operation (historical point-in-time figures as of September 2026, not service-level commitments). ATB is PayPal's availability-to-business service-level indicator.

models through their supported entry formats with no vendor keys to manage and no per-team provisioning. Gateway-level prompt-cache shaping reached hit rates of up to 96% on agentic coding workloads, which lowers input cost, since cache reads are billed at a discount [3], and can reduce time to first token, with no client changes.

13.3 Engineering assurance

The gateway is security- and cost-critical, so we treat its correctness as a product requirement. Continuous integration runs the Go and Rust test suites with a coverage floor, the policy test suite (which requires coverage of every production policy module), bundle validation, and the cross-language contract tests for the handoff, together with a build-failing coverage test for codec field classification. An extended suite adds database-backed tests for the control-plane stores and engine-parity tests between the previous Go engine and the OPA engine. A synthetic upstream service lets end-to-end tests and benchmarks run without vendor spend. The data plane, control plane and identity services comprise roughly 45k lines of Go and 7k lines of Rust, with about 35k further lines of Go tests.

14 Lessons Learned

L1. Wrap, don't rewrite. Putting Envoy in front of a working service and moving capabilities behind it one at a time required no client migrations, with no regressions observed during the monitored rollout. Measuring the share of traffic on the new path made progress visible.

L2. Split control from data by latency profile. Out-of-process for I/O-bound decisions and in-process for per-byte work let us be strict and fast at the same time. The same proxy foundation is what made voice scale: long-lived connections are multiplexed on Envoy's per-worker event loops rather than pinning per-session resources.

L3. Treat the connection lifecycle as a first-class design input. An HTTP request can be handed off and forgotten; a WebSocket must be held and then drained.

Upgrade, stream, idle and drain shaped most of our reliability decisions.

L4. Make models, prices and policy data, and validate them like code. Data-driven configuration is safe only with strict validation. A gateway that refuses to start on bad configuration is safer than one that starts and routes incorrectly.

L5. Store usage at the finest grain, keyed by immutable identifiers, and make every budget a view. This decision removed the need for data migrations when budgets or tags change, enabled rules that apply to the window to date, and made "what would this rule do now?" answerable.

L6. Keep decisions pure. Separating gather, decide and effect made policy testable and previewable, and made it possible to migrate engines under a parity harness.

L7. Ship governance in shadow mode, and warn before you block. Always-on tracking with separate enforcement switches let new controls prove themselves on real traffic before they blocked anyone, and threshold reminders gave users advance notice before limits applied.

L8. Anchor policy to stable identities. Rules that name organization leaders rather than team lists survive reorganizations without edits.

L9. Put the durable record where it is hardest to lose. Moving attribution from an in-application queue to the proxy's access log replaced silent, unbounded loss with a small, bounded loss window and made usage a system of record.

L10. Routing is not the differentiator. Off-the-shelf proxies route well. What our organization needed, and the off-the-shelf proxy we evaluated did not provide at the time, was real-time support, identity-aware authorization, organization-aware spend control and workload-identity-based cloud credentials.

15 Limitations and Future Work

Several limitations remain. Centralizing access also concentrates risk: the gateway brokers credentials for every provider, so it is a high-value target whose own access, secret handling and change control must meet the standard of the most sensitive workload it serves. Our experience comes from one large organization, and other environments may weigh these trade-offs differently. Our overhead benchmark covers the core request path, and production overhead depends on the policies and features enabled for a workload. Data-loss prevention relies on a learned detector whose accuracy varies by entity type, so it reduces rather than eliminates exposure. Budget thresholds, notification points and data-protection policies are organization-specific and require ongoing tuning against real usage; the mechanisms described here make that tuning safe, but do not remove the need for it.

Work in progress includes: a single credential for reaching every model, with automatic model fallbacks; additional providers; extending the same entry point to MCP tool calls and autonomous agents, with identity, policy and audit applied to every action; further safety and quality controls at the gateway; cost- and latency-aware routing and semantic caching, building on work such as [4, 16]; and richer, more proactive spend insights for owners.

16 Conclusion

The Cosmos LLM Gateway shows that, in one large enterprise, the problems of LLM access (credential sprawl, format lock-in, ungoverned spend and uneven governance) could be addressed at a single layer while adding a median of a few milliseconds of measured request-path overhead (section 13) for the developers and products that depend on it. The architecture rests on a few choices: governance out of process and translation in process; models, prices and policy as validated data; spend scopes as views over counters keyed by immutable model identifiers; pure policy decisions distributed as versioned bundles and introduced in shadow mode, with users normally warned before they are blocked; and a durable, priced usage record written where it is hardest to lose. Viewed this way, an enterprise LLM gateway is neither just a router nor just a policy engine. It is the platform layer that absorbs vendor multiplicity, credential variability and format heterogeneity into one governed substrate, so that a developer writes against one API, presents one identity, and reaches the right model through its supported entry formats with governance, attribution and observability applied by default.

Acknowledgments

We thank the PayPal Cosmos AI platform engineering, product and program teams, and the many internal teams who adopted the gateway early and shaped it with their feedback. All operational figures are historical, point-in-time aggregates; they are not service-level commitments and do not constitute forward-looking statements. The architecture described here provides technical controls only and does not by itself establish legal or regulatory compliance. Product and project names are trademarks of their respective owners.

References

[1] Agent Router Authors. Agent Router (formerly Envoy AI Gateway): Data plane and traffic flow. https://theagentrouter.ai/docs/concepts/architecture/data-plane, 2026. Agentic AI Foundation project. Accessed October 2026.

[2] agentgateway Authors. agentgateway: An AI-native proxy for agents, tools and models. https://agentgateway.dev, 2026. Agentic AI Foundation project. Accessed October 2026.

[3] Anthropic. Prompt caching. https://platform.claude.com/docs/en/build-with-claude/prompt-caching, 2026. Accessed October 2026.

[4] Lingjiao Chen, Matei Zaharia, and James Zou. FrugalGPT: How to use large language models while reducing cost and improving performance. *arXiv preprint arXiv:2305.05176*, 2023.

[5] Cloudflare. AI Gateway documentation. https://developers.cloudflare.com/ai-gateway/, 2026. Accessed October 2026.

[6] Envoy Project Authors. Envoy proxy documentation. https://www.envoyproxy.io/docs, 2026. Accessed October 2026.

[7] Envoy Project Authors. External processing filter (ext_proc). https://www.envoyproxy.io/docs/envoy/latest/configuration/http/http_filters/ext_proc_filter, 2026. Accessed October 2026.

[8] Martin Fowler. Strangler fig application (original text). https://martinfowler.com/bliki/OriginalStranglerFigApplication.html, 2004.

[9] Google. Gemini API: Thought signatures. https://ai.google.dev/gemini-api/docs/thinking#signatures, 2026. Accessed October 2026.

[10] M. Jones. JSON web key (JWK). RFC 7517, IETF, 2015.

[11] M. Jones, J. Bradley, and N. Sakimura. JSON web token (JWT). RFC 7519, IETF, 2015.

[12] Woosuk Kwon, Zhuohan Li, Siyuan Zhuang, Ying Sheng, Lianmin Zheng, Cody Hao Yu, Joseph E. Gonzalez, Hao Zhang, and Ion Stoica. Efficient memory management for large language model serving with PagedAttention. In *Proceedings of the 29th Symposium on Operating Systems Principles (SOSP '23)*, pages 611–626, 2023.

[13] Microsoft. AI gateway capabilities in Azure API Management. https://learn.microsoft.com/en-us/azure/api-management/genai-gateway-capabilities, 2026. Accessed October 2026.

[14] Model Context Protocol Authors. Model context protocol specification. https://modelcontextprotocol.io/specification, 2026. Accessed October 2026.

[15] NVIDIA. Dynamo: A datacenter-scale distributed inference serving framework. https://github.com/ai-dynamo/dynamo, 2026. Accessed October 2026.

[16] Isaac Ong, Amjad Almahairi, Vincent Wu, Wei-Lin Chiang, Tianhao Wu, Joseph E. Gonzalez, M. Waleed Kadous, and Ion Stoica. RouteLLM: Learning to route LLMs from preference data. In *International Conference on Learning Representations (ICLR)*, 2025.

[17] Open Policy Agent Authors. Open policy agent: Policy-based control for cloud native environments. https://www.openpolicyagent.org/docs, 2026. Accessed October 2026.

[18] OpenTelemetry Authors. OpenTelemetry specification. https://opentelemetry.io/docs/specs/otel/, 2026. Accessed October 2026.

[19] Ruoming Pang, Ramón Cáceres, Mike Burrows, Zhifeng Chen, Pratik Dave, Nathan Germer, Alexander Golynski, Kevin Graney, Nina Kang, Lea Kissner, Jeffrey L. Korn, Abhishek Parmar, Christina D. Richards, and Mengzhi Wang. Zanzibar: Google's consistent, global authorization system. In *Proceedings of the 2019 USENIX Annual Technical Conference (USENIX ATC '19)*, pages 33–46, 2019.

[20] Portkey AI. Gateway: An open-source AI gateway. https://github.com/Portkey-AI/gateway, 2026. Accessed October 2026.

[21] Proxy-Wasm Authors. WebAssembly for proxies (ABI specification). https://github.com/proxy-wasm/spec, 2026. Accessed October 2026.

[22] N. Sakimura, J. Bradley, M. Jones, B. de Medeiros, and C. Mortimore. OpenID Connect core 1.0. OpenID Foundation, 2014.

[23] PayPal AITech Cosmos AI Team. One connection. 2,000 tools. PayPal Developer Community Blog, October 2026. https://developer.paypal.com/community/blog/One_connection_2000_tools/.

[24] Lianmin Zheng, Liangsheng Yin, Zhiqiang Xie, Chuyue Sun, Jeff Huang, Cody Hao Yu, Shiyi Cao, Christos Kozyrakis, Ion Stoica, Joseph E. Gonzalez, Clark Barrett, and Ying Sheng. SGLang: Efficient execution of structured language model programs. In *Advances in Neural Information Processing Systems (NeurIPS)*, 2024.

A Registry Excerpt

Abridged and sanitized. The model identifier is illustrative and prices are placeholders (USD per million tokens). Provider, credential and path configuration are omitted.

```
families:     { chat: {}, responses: { canonical_format: openai_responses }, embeddings: {} }
wire_formats: { anthropic_messages: { family: chat }, openai_chat: { family: chat },
                anthropic_vertex: { family: chat }, gemini_generate_content: { family: chat },
                openai_responses: { family: responses } }
converters:
  - { from: anthropic_messages, to: openai_chat }
  - { from: anthropic_messages, to: anthropic_vertex }
  - { from: anthropic_messages, to: openai_responses }
  - { from: anthropic_messages, to: gemini_generate_content }
  - { from: openai_chat,        to: anthropic_vertex }
  - { from: openai_chat,        to: openai_responses }
  - { from: openai_chat,        to: gemini_generate_content }
models:
  claude-opus-x:                                  # illustrative model id
    brand: anthropic
    entry_formats: [anthropic_messages, openai_chat]
    aliases: [claude-opus-x-latest]
    tags: [all, claude, opus, proprietary, frontier]
    deployments:
      - id: opus-x@cloud
        provider: <cloud-ai-platform>
        region: global
        deployment_format: anthropic_vertex
        priority: 1
        pricing: { unit: usd_per_mtok, input: <in>, output: <out>,
                   cache_read: <cr>, cache_write: <cw>, cache_write_1h: <cw1h>,
                   threshold_tokens: <n>,                    # optional long-context tier
                   long: { input: <in2>, output: <out2>, cache_read: <cr2>, cache_write: <cw2> } }
```

B Spend Rule Language

Each rule holds one or more entries; each entry reads as one sentence: *when* a user's spend in a scope crosses a threshold within a window, *do* these actions. Identifiers, weights, amounts and template names are illustrative placeholders, not production values. `scope` is a registry tag or a single model identifier and is resolved at evaluation time (section 9.2). Rules default to *enabled*, because a cap someone forgot to enable silently does nothing, which is the worse failure for cost control. Whether an enabled rule can block is governed separately by the enforcement mode (section 10.4). The first rule below shows the reminder pattern: a warning email at 90% of an allowance, then a block and a second email at 100%.

```
rules:
  - id: frontier-family-monthly          # stable id; surfaces in metrics
    weight: 60                           # precedence (higher first)
    matches:
      - match: { tiers: [normal], scope: opus, window: monthly, at_or_above_usd: <0.9 x T> }
        actions:
          - { type: email, to: [user], subject: "You're at 90% of your monthly limit", body_file: <template> }
      - match: { tiers: [normal], scope: opus, window: monthly, at_or_above_usd: <T> }
        actions:
          - { type: email, to: [user], subject: "Monthly limit reached", body_file: <template> }
          - { type: block }              # stateless; clears when the window rolls
  - id: daily-pause
    weight: 50
    matches:
      - match: { scope: all, window: daily, at_or_above_usd: <D> }
        actions:
          - { type: pause, hours: <H> }  # one-shot per (rule, window); self-lifts
          - { type: message, level: warn, text: "Paused. Resumes {resume_time}." }
          - { type: email, to: [user] }
  - id: org-monthly-cap
    weight: 100
    matches:
      - match: { tiers: [normal, pro], scope: all, window: monthly, leaders: [<org-leader>],
                 exempt_users: [<login>], at_or_above_usd: <B> }
        actions:
          - { type: block }
          - { type: message, level: warn, text: "You have reached your organization's monthly per-person limit." }
  - id: weekly-leadership-awareness
    weight: 40
    matches:
      - match: { tiers: [normal, pro], scope: all, window: weekly, at_or_above_usd: <W> }
        actions:
          - { type: email, to: [leadership] }   # deferred digest after the window boundary
```

C Usage Record

One row per request in a day-partitioned warehouse table, clustered by caller and model, read through a view that deduplicates on the request ID.

Field group	Fields	Origin
Identity of the request	request id (gateway-generated), timestamp, trace id	Envoy
Caller	user, application, tier, platform/workflow/harness tags (one JSON object)	control (request phase)
Routing	requested model, canonical model, vendor, entry and upstream formats, resource type	control (request phase)
Usage	input, output, cache-read, cache-write (incl. extended-lifetime) tokens	Wasm trailers
Cost	per-component and total USD; workflow spent/limit when present	control (trailer phase)
Outcome	status, response flags, duration, time to first byte, upstream cluster	Envoy